

# Lab 04 Prompts: Add API-Key Protection and CORS

Course: Create RESTful APIs and Web Apps with Python Flask Course code: TGS-2021010365 Version: v11.0  
Maps to: A7, A8

## Prompt execution contract

Use `python ai_vibe.py --dry-run` to inspect the exact request. The script uses the OpenAI Python SDK Responses API with a Pydantic CodeBundle. It writes drafts only to `working-files/generated/`; it never overwrites trusted source. Keep `OPENAI_API_KEY` in the shell, not in prompts, files, screenshots or browser JavaScript.

## Learner prompt - copy exactly for the first run

You are working on Lab 04 of a Northstar Commerce API. Add a reusable X-API-Key dependency to product, customer and order write routes and configure CORS for only the origin supplied in `mock-data.json`. Read secrets from environment variables, compare safely, never place a live key in source or browser JavaScript, and test missing, invalid and valid credentials.

Use only the synthetic context in `mock-data.json` and the current project files supplied by `ai_vibe.py`. Preserve existing API behaviour unless this prompt explicitly changes it. Use Python 3.11+, FastAPI, Pydantic v2, SQLite parameter binding and pytest/TestClient. Do not include secrets, database files, caches or invented test results. Return a typed CodeBundle containing complete file contents for only these targets:

- `app/security.py`
- `app/main.py`
- `tests/test_security.py`

For every generated file, state its purpose. Include assumptions and concrete verification commands. The learner will review the diff and run the commands before accepting any code.

## Evidence-led refinement prompt

The previous generated bundle did not yet pass the acceptance check below. Use the pasted failure evidence, identify the smallest contract or implementation mismatch, and return a revised CodeBundle containing only files that must change. Do not weaken or delete a passing test.

Acceptance check: Unauthorized writes return 401; a valid key succeeds; only the configured origin receives CORS permission.

Paste exact evidence here:

```
HTTP request/response, traceback, assertion diff or log request ID
```

## Review checklist

- Confirm every generated path is inside `working-files/generated/`.
- Reject hard-coded keys, personal data, f-string SQL and unrestricted CORS.
- Compare generated behaviour with the written API contract and mock data.
- Run `pytest -q`; inspect status, JSON and SQLite state, not only the exit code.
- Record prompt, model name, assumptions, accepted diff and final evidence.

